

VAPT on Web Application Report

Project Title

Vulnerability Assessment and Penetration Testing (VAPT) on Web Application

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify vulnerabilities present in an application or system. This project focuses on testing a vulnerable web application in a controlled laboratory environment using DVWA (Damn Vulnerable Web Application).

The objective is to identify common web application vulnerabilities, understand their impact, and study their mitigation techniques.

2. Objective

The objectives of this project are:

- To perform vulnerability assessment on a web application.
- To identify common security vulnerabilities.
- To analyze the impact of vulnerabilities.
- To understand prevention and mitigation techniques.

3. Lab Environment

Attacker Machine

- Kali Linux

Target Machine

- Metasploitable2

Web Application

- DVWA (Damn Vulnerable Web Application)

Target IP Address

192.168.74.128

Security Level

Low

4. Tools Used

- Kali Linux
- Metasploitable2
- DVWA
- Nmap
- Web Browser

5. Methodology

The following steps were performed:

1. Network connectivity verification.
2. Target machine scanning using Nmap.
3. Accessing DVWA web application.
4. Testing different web application vulnerabilities.
5. Documenting findings and mitigation methods.

6. Vulnerability Assessment

6.1 SQL Injection

Description

SQL Injection is a vulnerability where an attacker can manipulate SQL queries through user input fields.

Testing

Normal Input:

1

Result:

A single user record was displayed.

Payload:

1' OR '1'='1

Result:

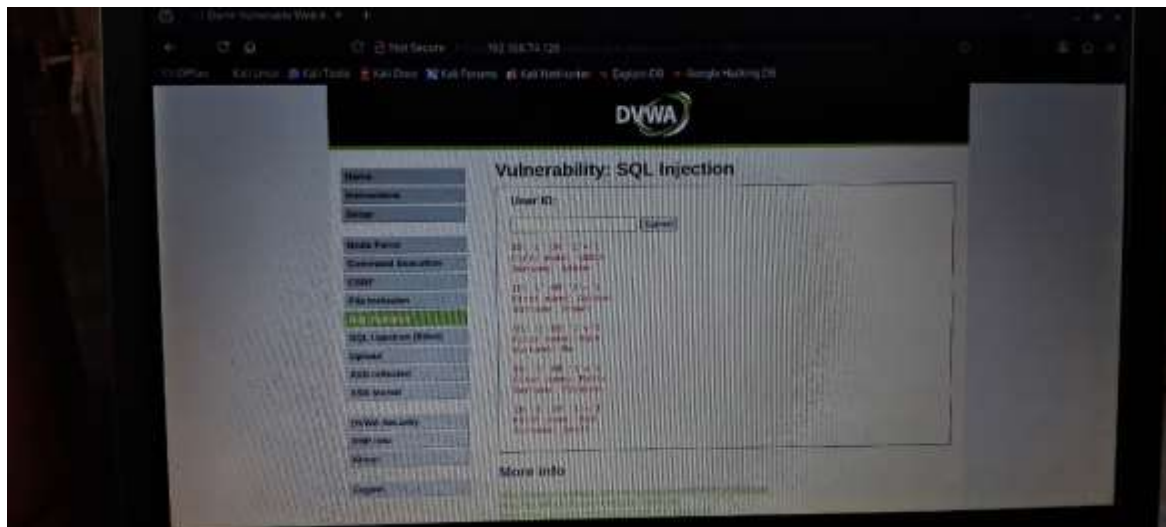
Multiple user records were displayed, confirming SQL Injection vulnerability.

Impact

An attacker may access unauthorized database information.

Mitigation

- Use prepared statements.
- Validate user input.
- Apply secure database practices.



6.2 Reflected XSS

Description

Reflected Cross-Site Scripting occurs when user input is reflected back by the application without proper validation.

Payload

```
<script>alert('XSS')</script>
```

Result

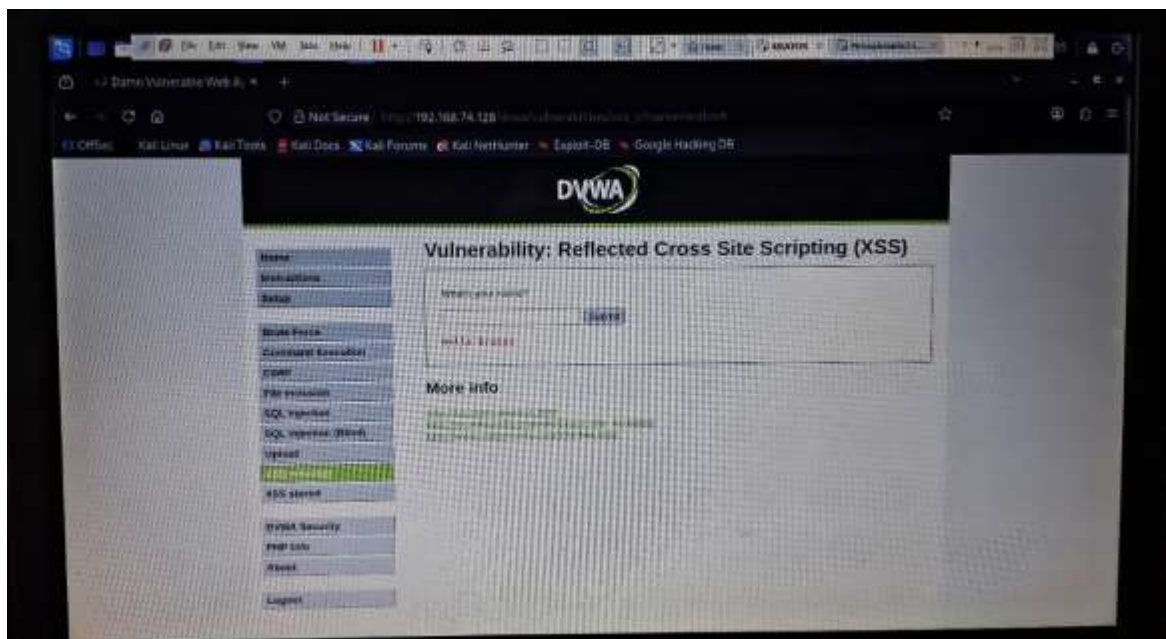
A JavaScript alert box was displayed, confirming successful execution.

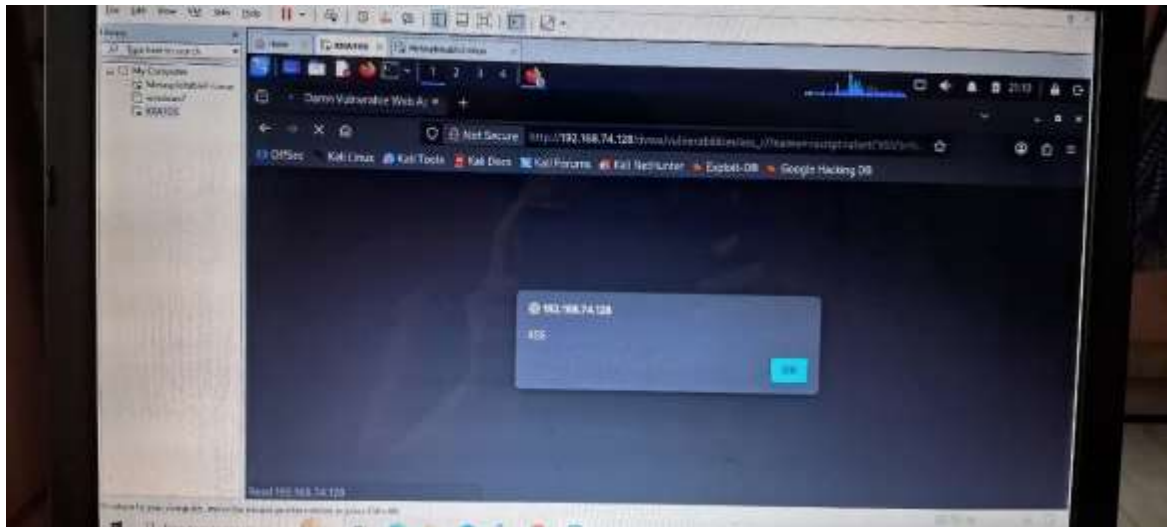
Impact

An attacker may execute malicious scripts in a user's browser.

Mitigation

- Validate input.
- Encode output.
- Implement Content Security Policy.





6.3 Stored XSS

Description

Stored XSS occurs when malicious scripts are permanently stored by the application and executed when users access the affected page.

Payload

```
<script>alert('Stored XSS')</script>
```

Result

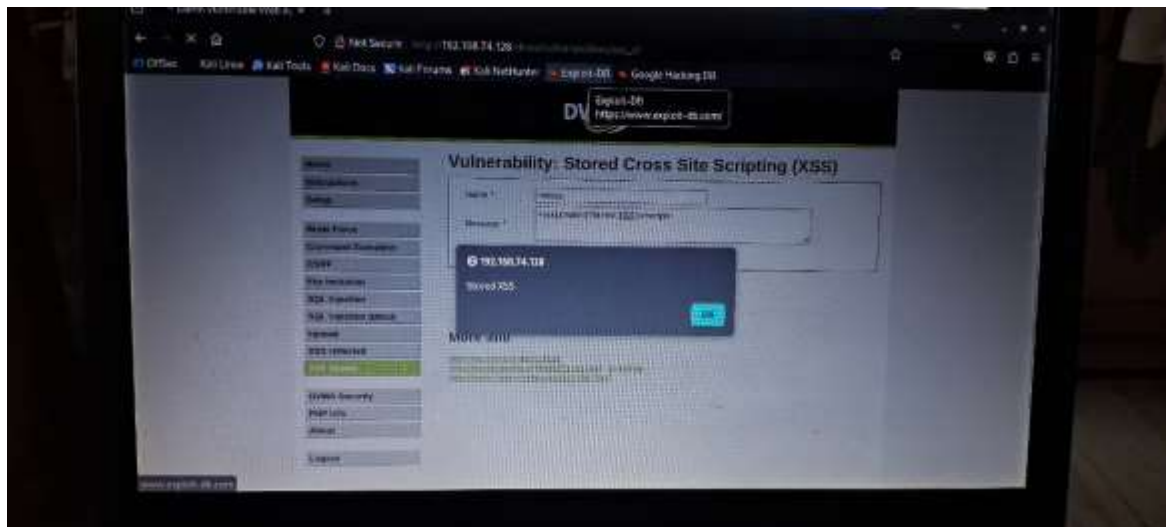
The payload was stored and executed when the page was loaded again.

Impact

Multiple users can be affected by stored malicious scripts.

Mitigation

- Sanitize user input.
- Encode output.
- Apply secure coding practices.



6.4 Command Injection

Description

Command Injection occurs when an application executes system commands using unsanitized user input.

Input

127.0.0.1 && whoami

Result

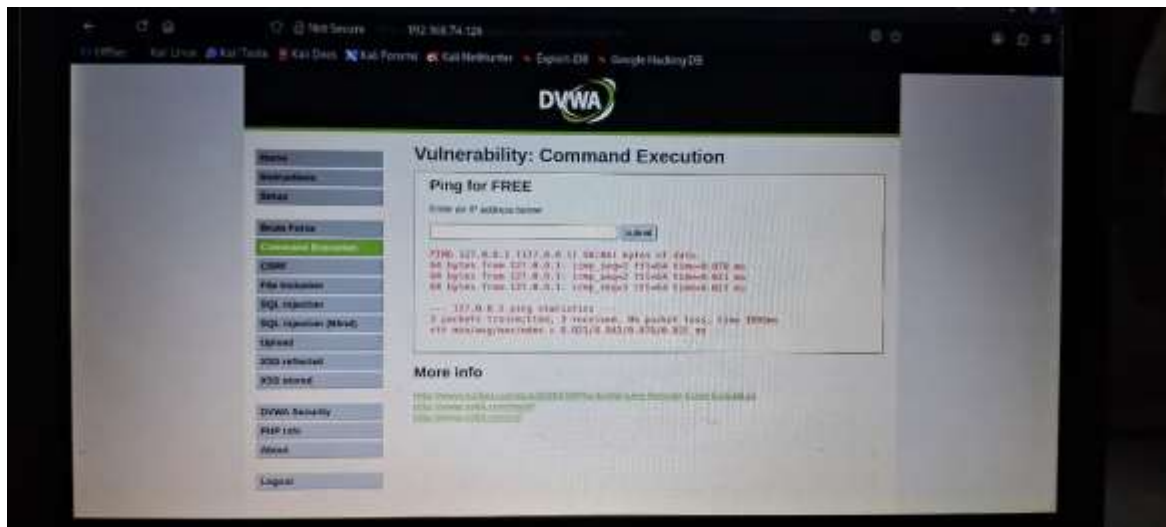
The additional command was executed along with the ping request.

Impact

An attacker may execute unauthorized commands on the server.

Mitigation

- Avoid direct command execution using user input.
- Use secure APIs.
- Implement strict input validation.



6.5 File Upload

Description

File Upload vulnerability occurs when an application allows file uploads without proper validation.

Testing

A test image file was uploaded using DVWA File Upload functionality.

File:

test.jpg

Result

File uploaded successfully.

Upload Location:

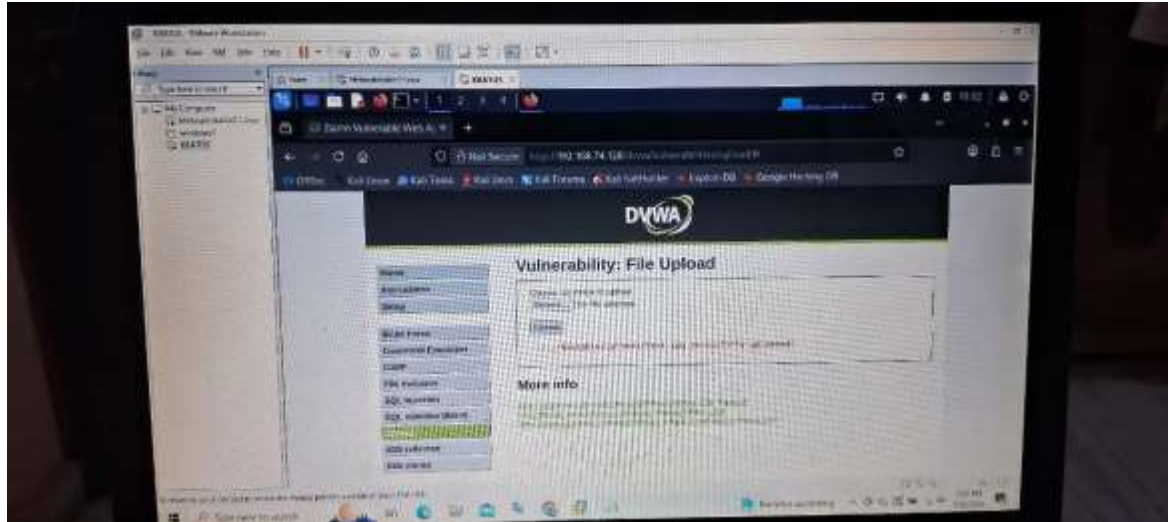
../../hackable/uploads/test.jpg

Impact

Attackers may upload malicious files if proper restrictions are not implemented.

Mitigation

- Validate file extensions.
- Check MIME types.
- Restrict executable uploads.
- Store files securely.



6.6 Brute Force

Description

Brute Force vulnerability occurs when an application allows repeated login attempts without proper security controls.

Credentials Tested

Username:

admin

Password:

password

Result

Successful login achieved.

Message:

8. Conclusion

This project successfully demonstrated Vulnerability Assessment and Penetration Testing techniques on a vulnerable web application in a controlled laboratory environment.

Multiple web vulnerabilities were identified, tested, and documented along with their impacts and mitigation techniques.

The project helped in understanding practical web application security testing concepts.

9. Disclaimer

This project was performed only in a controlled educational environment using DVWA. The testing activities were conducted for learning and security awareness purposes only.